Login-Watchdog 발표 대본

'어떡하죠?' 팀 · 발표 정성원 · 전체 예상 시간 약 13~15분 (라이브 시연 포함)

동작 클릭·화면 전환 (읽지 않음) / 잠깐 숨 쉬는 자리 **나머지 본문**은 그대로 읽는 말

준비 발표 전 준비 — 라이브 시연용

1. docker compose로 Track D 단지를 켜 두고, 시연용 .env 적용 확인
2. 터미널 하나를 저장소 루트에 열어 두고 명령을 미리 입력만 해 둔다 (엔터는 시연 때)

   ```
   python -m scripts.net.run_all --repeat 1
   ```

   - S6까지 보려면 같은 창에 victim 비밀번호 환경변수(LW_VICTIM_PASSWORD)를 미리 넣어 둔다. (없으면 S6만 SKIP — 실패로 치지 않음)
3. 크롬에서 관리자 로그인 → 확장 프로그램 미니 창(Alt+Shift+W) 열어 두기
   - 확장 옵션에서 확인 간격을 5초(최소값)로 바꿔 두기 (기본 10초면 반응이 늦어 보임)
   - 시작 전 미니 창이 "정상 — 최근 30분 공격 없음" 상태인지 확인 (리허설 직후라면 30분이 지나야 초기화됨 — 리허설은 발표 30분 전까지 끝내기)
4. 화면 배치: 발표 자료(전체 화면) / 터미널 + 미니 창은 Alt+Tab 한 번에 나오게
5. 참고: 실행하면 docs/track-d/scenario-results.md 에 결과 줄이 덧붙여짐 (발표 후 정리)

01 표지

> 안녕하세요, '어떡하죠?' 팀 조장 정성원입니다.
>
> 저희 프로젝트는 Login-Watchdog 이라는
>
> 로그인 공격을 / 탐지하고, 판단하고, 대응하고, 복구까지 / 한 번에 처리하는 보안 관제 시스템으로
>
> 저와 조원 편승훈, 유지은, 김재호가 함께 만들었습니다.

02 목차

> 프로젝트 개요, 구성, L7 기능, 핵심인 L3/L4 기능, 검증 결과, 트러블슈팅과 한계점, 질의응답 순서로 진행해보겠습니다.

03 01 · 개요 배경

초기 주제를 정할 때 팀원들의 역량과 전공 직군이 제각각인 점을 고려하여

누구나 직관적으로 이해할 수 있으면서도, 단계적으로 확장하기 쉬운 '로그인 보안 관제'를 주제로 선정했습니다.

처음에는 가장 접하기 쉬운 L7 웹 로그인 단계에서 출발해,

이후 L4와 L3 영역으로 점차 심화 적용 영역을 넓혀나갔습니다.

04 01 · 개요 목표

기존의 수동 대응 방식은 경보가 발생한 뒤에도 담당자가 로그를 확인하고,

공격 여부를 판단한 다음, 차단 명령을 적용해야 했기 때문에

대응 시간이 작업자의 확인 시점에 따라 달라졌습니다.

이를 개선하기 위해 탐지, 판단, 차단, 복구의 4단계를 하나의 자동 대응 흐름으로 구조화했습니다.

05 01 · 개요 일정

일정은 8월 주제 기획부터 시작해서

9월에 L7 및 SIEM·SOAR 구축,

10월에 L3/L4 계획서인 Track D 설계와 협업을 진행하였고,

29일에 시나리오 테스트를 완료했습니다.

06 01 · 개요 역할

조장인 저는 통합을 맡아 L7 전체, 병합·배포, 관제 화면, 실측과 문서를,

A 편승훈은 Docker 단지와 센서 탐지, 공격 재현,

B 김재호는 서명된 경보 수집과 교차 규칙, 플레이북,

C 유지은은 L4 차단·해제와 시나리오 점검을 맡았습니다.

A가 경보를 보내면 B가 판단해서, C에게 차단을 요청하는 구조입니다.

07 01 · 개요 학습

키워드를 먼저 탐구하고 직접 구현해 본 뒤,
Aleph 강의를 통해 개념을 체계화했습니다.
수업내용을 이해하는 데 그치지 않고 이를 다시 적용하고 검증하며
부족했던 부분을 보완해 프로젝트에 반영했습니다.

대표적으로 SIEM·SOAR는 9월에 먼저 구현한 후
10월 강의 내용을 바탕으로 탐지·자동 대응 구조를 고도화했고,
RBAC와 PDP·PEP도 같은 방식으로 실제 보안 기능으로 연결했습니다.

08 02 · 구성 유스케이스

RBAC으로 나눈 관리자는 세 등급입니다.
최고 관리자는 영구 잠금 해제나 관리자 계정 관리 같은 큰 권한을,
보안 관리자는 잠금·차단 해제와 사건 처리를,
보안 조회자는 관제 보드 조회만 할 수 있으며
모든 요청은 권한 검사를 먼저 거칩니다.

09 02 · 구성 구조도

시스템 구조도를 보시면
가운데 Flask 앱이 화면·API, 탐지·등급, 상관분석, SOAR·차단을 처리하고,
DB는 Supabase, 관제 화면은 Next.js,
Groq LLM을 이용한 조기 경보, Slack과 메일로 즉시 알림을 보냅니다.
Track D는 Docker 위에서 실행되며
센서가 패킷을 보고, 경보 전송기인 shipper가 HMAC 서명을 붙여 보내면서,
차단기인 fw-agent가 nginx 정문의 ipset에 차단 목록을 반영합니다.

10 02 · 구성 ERD

DB는 35개 테이블 중 핵심 10개만 보여드립니다.
왼쪽이 L7, 아래가 L3/L4 이고
가운데 security_events와 security_incidents에서
L7 경보와 L3/L4 경보가 하나로 합쳐져 판단됩니다.

11 03 L7 기능

L7 기능입니다.

브루트포스 — 60초에 5번 실패, 그리고 스프레이, 매크로·봇, 웹 스캐닝, HTTP 플러딩 등을 탐지하며

위험등급 네 단계 분류 및 SIEM으로 사건을 묶고, LLM이 조기 경보를 냅니다.

대응으로 임시 5분 잠금, 30일 안에 두 번이면 영구 잠금,

SOAR 플레이북과 Slack·메일 알림이 자동으로 진행됩니다.

복구는 메일 인증, 비밀번호 재설정, 관리자 해제로 풀 수 있습니다.

12 04 핵심 L3/L4 기능

이제 핵심인 L3/L4입니다.

탐지는 SYN 폭주, 포트 스캔, ICMP 폭주, 위조 출발지 / 네 가지고,

센서 경보는 HMAC 서명을 붙여서 보냅니다.

판단은 단독 폭주 NET-01과,

L3/L4와 L7을 엮는 교차 규칙 CR-01, 02, 03입니다.

차단 방식은

연결이 확인되면 영구 차단,

출발지가 위조됐을 수 있으면 시간 제한만,

L3 경보는 속도 제한만 거는 방식으로 3가지로 진행됩니다.

실패하면 재시도하고, 저희 서버 인프라 주소는 막지 않습니다.

13 04 시연 영상 ① 정찰 → 침투

영상 약 1분

> ※ 영상이 0초부터 자동 재생됨. 말은 짧게, 화면 따라가기.

0초 영상 시작	정찰 후 침투로 이어지는 시연영상입니다.
~4초 포트 스캔	먼저 포트 스캔으로 / 문을 흔들어 봅니다.
~17초 로그인 공격	이어서 같은 IP가 / 로그인 공격을 합니다.
~31초 정찰+침투 판단	두 경보가 묶여서 / CR-01, 정찰 후 침투로 판단됩니다.
~44초 영구 차단	정문에서 영구 차단.
~59초 대조 IP 정상	옆의 대조 IP는 / 그대로 정상 접속됩니다.

14 04 시연 영상 ② SYN 폭주

영상 약 40초

0초 영상 시작	이번엔 문만 두드리고 도망가는 공격, SYN 폭주입니다.
~3초 SYN 폭주	SYN 패킷이 쏟아지고,
~12초 센서 탐지	센서가 잡아서,
~19초 서명 경보	서명된 경보로 보냅니다.
~26초 정문 TTL 차단	출발지 위조 가능성이 있어서 / 영구가 아니라 시간 제한 차단입니다.
~35초 관제 화면 확인	관제 화면에도 바로 올라옵니다.

★ LIVE 라이브 시연 — 확장 프로그램 + run_all

약 1분 30초

시연 영상 ② 와 검증 결과 페이지 사이

> ※ **실행 타이밍**: 영상 ②가 끝나고 '관제 화면 확인' 장면이 나온 직후, "영상 말고 지금 직접 보여드리겠습니다" 라고 말하면서 화면 전환 → 바로 엔터.
> 먼저 실행하고 그다음에 설명한다 (첫 신호가 몇 초 안에 오므로 기다리는 시간이 없음).
> ※ 한 번 실행에 S4 → S5 → S5b → S6 → S7 → S8 → S9 순서, 전체 약 1분 10초. 첫 시나리오(S4) 결과가 10~20초 안에 나오고, 미니 창은 5초마다 확인.

화면 전환: 터미널 + 미니 창

실제로 한번 정상적으로 기능을 하는지 보겠습니다.

오른쪽 위 작은 창이 / 저희가 만든 크롬 확장 프로그램, 미니 관제창입니다.

다른 화면을 보고 있어도 / 항상 위에 떠 있습니다.

지금은 "정상" 상태죠.

엔터 — run_all --repeat 1 실행

지금 시나리오 일곱 개를 / 새 IP로 한 번씩 공격하게 실행했습니다.

첫 경보가 미니 창에 뜨면 — 10~20초 안

바로 뜨죠. / 등급이 올라가고 "공격 탐지 중"으로 바뀌었습니다.

(크롬 알림이 오면) 알림도 같이 옵니다.

터미널에 S4 PASS 가 찍히면

터미널에는 시나리오마다 / 실제로 DB에 차단이 생겼는지 확인해서 / PASS가 찍힙니다.

나머지가 도는 동안 — 미니 창 가리키며

최근 30분 그래프에 / 공격이 쌓이는 게 보이고요,

아래 '지금 일어나는 공격' 목록이 / 계속 올라옵니다.

다시 발표 자료로 전환

※ 만약 대비

- **1분이 넘게 걸리면**: 끝까지 기다리지 말고 "나머지는 뒤에서 계속 돕니다" 하고 다음 장으로. (끝 결과는 Q&A 때 한 번 보여주기)
- **FAIL·오류가 나면**: "현장 네트워크 상황 때문인데요, 같은 점검을 10월 29일에 7개 모두 통과한 결과를 다음 장에서 보여드리겠습니다" 하고 바로 검증 결과로 넘어가기.
- **미니 창이 안 바뀌면**: 관제 화면(대시보드) 탭으로 전환해서 보여주기.

15 05 검증 결과

자동 테스트는 총 1,492개를 모두 통과했고, 그중 751개가 Track D입니다.

시나리오도 S4부터 S9까지 총 7개 전부 통과했습니다.

탐지부터 차단까지 목표는 5초였는데, 실제로는 센서 탐지 후 경보까지

2.1초, 차단 반영까지 0.6초로 총 2.7초 만에 처리됐습니다.

16 06 문제와 해결 과정

피드백을 받아 보완한 것 중 세 가지만 말씀드리면,

첫째, 변장 공격입니다.

공격자가 출발지를 우리 서버로 위조하면 / 오히려 우리 서버가 차단되는 문제가 있어

내부 주소는 차단 대상에서 제외했습니다.

둘째, 조용한 실패입니다.

차단에 실패해도 아무 신호 없이 묻혀 버리는 문제가 있어, / 3회 재시도 후에도 실패하면 알림을 보내도록 했습니다.

셋째, 어긋난 시계입니다.

컨테이너 간 시계가 최대 7초까지 차이 나는 문제가 있어, / 시각 기준을 DB 하나로 통일했습니다.

17 06 남은 과제

현재 프로젝트의 남은 과제입니다.

첫째, L3/L4 차단은 아직 로컬에서만 동작해서 다음 단계로 클라우드 방화벽으로 확장하려 합니다.

둘째, 부하가 몰릴 때 지연이 최대 7.2초까지 늘어나는 것을 확인하고 푸시 방식의 즉시 알림을 도입할 계획입니다.

셋째, 공유 IP 환경에서는 여러 사용자가 함께 잠기는 문제가 있어 계정과 기기를 함께 판단하는 방향을 고려하고 있습니다.

마지막으로, 위조된 출발지에 시간 제한만 적용한 것은 / 무고한 사용자의 차단을 막기 위한 의도된 선택입니다.

18 Q&A

> 이상으로 발표를 마치겠습니다.
>
> 질문 있으시면 편하게 해 주세요. / 감사합니다.